

SIKAFLOW SECURITY GOVERNANCE & POLICY FRAMEWORK

Course: Thrive Africa Cybersecurity Internship

Week: Week 5 – Security Governance & Policy Development

Group Name: Group 3

Group Members:

- Edwin Mensah-Sabah
- Cornelius McCarthy
- Ebenezer Brookman
- Sarpong Matthew Kweku
- Bismark Fiifi Arthur
- Collins Amponsah
- David Attuah-Asante
- Armah Lawrencia Naa Ayeley

Organization: Sikaflow (Fintech Startup – Ghana)

Submission Date: 24th April, 2026

Prepared By:

Group 3 – Cybersecurity Team

Confidentiality Level: Internal Use Only

DOCUMENT CONTROL

Document Title: Sikaflow Security Governance & Policy Framework

Document ID: SF-GOV-SEC-001

Classification: Internal Use Only

Version: 1.0

Status: Approved

Date Created: 22nd April, 2026

Last Updated: 24th April, 2026

Next Review Date: 24th April, 2027

Document Control and Governance

This section records the formal review, approval, and endorsement of this document in accordance with Sikaflow’s governance standards.

Name	Role	Responsibility	Signature	Date
Ebenezer Brookman	Security Lead	Technical Review (Security Compliance, Risk Alignment)	E.B	22 nd April, 2026
Cornelius McCarthy	I.T Manager	Formal Approval (Operational & IT Governance Authority)	C.M	22 nd April, 2026
Edwin Mensah-Sabah	Group Leader	Executive Endorsement (Project Oversight & Strategic Alignment)	E.S	22 nd April, 2026

Version History

Version	Date	Description of Change	Author
1.0	22 nd April,2026	Initial Release of Security Governance & Policy Framework	Group 3

Document Purpose

This document establishes the security governance framework, roles, responsibilities, and policy structure for Sikaflow. It defines the controls required to protect organizational assets, ensure regulatory compliance, and manage cybersecurity risks identified within the organization's risk register.

Scope

This document applies to:

- All Sikaflow employees and contractors
 - All IT systems, infrastructure, and applications
 - All organizational data, whether stored, processed, or transmitted
 - All business units and operational environments
-

Document Distribution

This document is distributed to:

- Executive Management
 - IT Security Team
 - System Administrators
 - All Employees (read-only access)
-

Document Review Cycle

- This document must be reviewed **annually** or upon significant organizational, technological, or regulatory change.
- The Security Lead is responsible for initiating the review process.
- The IT Manager ensures implementation alignment after approval updates.

SECTION 1: SECURITY ROLES & RESPONSIBILITIES

Effective security governance at Sikaflow requires clearly defined roles to ensure accountability and proper management of information assets.

1.1 Key Roles

Management / Board

- Approves security policies and provides strategic direction
- Ensures adequate resources are allocated for cybersecurity

Chief Information Security Officer / Security Lead

- Oversees the organization's cybersecurity strategy
- Ensures policies are implemented and enforced
- Manages risk and compliance activities

IT Security Team

- Monitors systems for threats and vulnerabilities
- Responds to security incidents
- Conducts regular security assessments

System Administrator

- Maintains server security (patching, configurations)
- Disables vulnerable services (e.g., FTP, Telnet)
- Monitors system performance and logs

Network Administrator

- Configures firewalls and network security controls
- Implements network segmentation
- Monitors traffic for suspicious activity

Database Administrator

- Secures databases and manages access control
- Performs backups and ensures data integrity

Employees (Users)

- Follow all security policies
 - Protect login credentials
 - Report security incidents promptly
-

1.2 Data Roles and Responsibilities

Effective data governance at Sikaflow requires clearly defined roles to ensure accountability for the protection, integrity, and proper use of data assets.

Data Owner

The Data Owner is responsible for the overall classification, protection, and appropriate use of data within the organization.

Responsibilities:

- Define data classification levels (e.g., confidential, internal, public)
- Determine who is authorized to access specific data
- Approve access requests to sensitive information
- Ensure data is handled in accordance with regulatory and business requirements
- Assess risks associated with data assets and ensure appropriate controls are in place

Example: Product Manager, Business Unit Head

Data Custodian

The Data Custodian is responsible for the technical implementation and maintenance of security controls that protect data.

Responsibilities:

- Implement access controls defined by the Data Owner

- Secure storage of data (databases, servers, backups)
- Perform regular data backups and ensure recovery processes are in place
- Apply encryption and other technical safeguards
- Monitor systems for unauthorized access or anomalies
- Ensure systems are patched and configured securely

Example: Database Administrator, IT Security Team

Data User

The Data User is any individual who accesses and uses data to perform their job responsibilities.

Responsibilities:

- Access data only as authorized
- Protect login credentials and sensitive information
- Follow all security policies and procedures
- Avoid sharing data with unauthorized individuals
- Report any suspected data breaches or security incidents immediately

Example: Employees, Analysts, Customer Support Staff

Accountability Principle

All data-related activities must follow the principle of accountability, where:

- Data Owners are accountable for data protection decisions
- Data Custodians are responsible for implementing controls
- Data Users are responsible for compliant usage

This ensures that data security risks identified in the organization's risk register—such as database exposure, unauthorized access, and data leakage—are effectively managed.

SECTION 2: GOVERNANCE STRUCTURE

Sikaflow adopts a structured approach to cybersecurity governance to ensure accountability and effective risk management.

2.1 Governance Model

- **Management** provides oversight and approves all security policies
- **CISO / Security Lead** is responsible for enforcing policies and managing risks
- **IT and Security Teams** implement technical controls and monitor systems
- **Employees** are responsible for complying with policies

2.2 Decision-Making Structure

Security decisions are based on:

- Risk assessments (from the organization's risk register)
- Business priorities and operational needs
- Regulatory and compliance requirements

2.3 Risk-Based Approach

All security controls and policies are designed to address identified risks, including:

- Unauthorized access (FTP, Telnet, Bind Shell)
- Data breaches (MySQL exposure)
- Network attacks (SMB vulnerabilities, DoS attacks)

2.4 Governance Principle

Sikaflow follows a risk-based governance model aligned with industry best practices such as ISO/IEC 27001, ensuring that security is integrated into all business processes.

SIKAFLOW SECURITY GOVERNANCE STRUCTURE

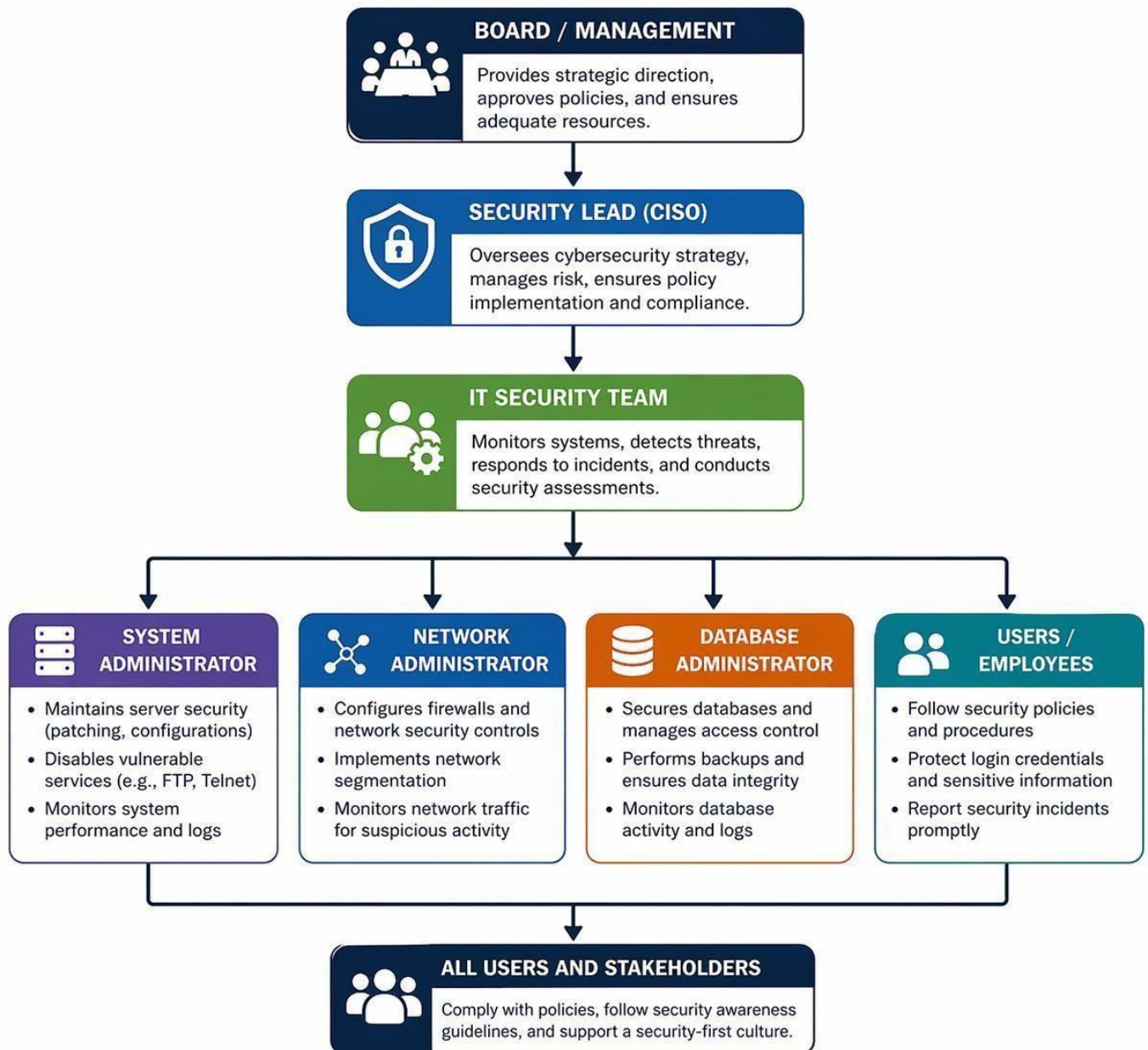


Figure: Sikaflow Security Governance Structure

This diagram illustrates the cybersecurity governance framework of Sikaflow, showing the hierarchy of roles and responsibilities. Management provides strategic oversight and approves security policies, while the Security Lead (CISO) is responsible for enforcing policies and managing organizational risk. The IT Security Team handles monitoring, incident response, and security operations. Technical roles such as System, Network, and Database Administrators implement and maintain security controls, while all users are responsible for complying with established security policies. This structure ensures accountability and supports a risk-based approach to managing cybersecurity threats.

SECTION 3: SECURITY POLICIES FOR SIKAFLOW

SIKAFLOW INFORMATION SECURITY POLICY

1. POLICY OVERVIEW AND CONTEXT

Sikaflow operates in an environment where information systems, customer data, and financial systems are exposed to increasing cybersecurity threats. This policy establishes a structured approach to managing information security risks and ensuring the protection of organizational assets.

The policy aligns with industry best practices and supports secure business operations, regulatory expectations, and risk management objectives.

2. PURPOSE

The purpose of this policy is to protect Sikaflow's information systems and data from unauthorized access, disclosure, modification, destruction, or disruption, while ensuring business continuity and regulatory compliance.

3. SCOPE

This policy applies to:

- All employees, contractors, and third-party users
 - All IT systems, applications, databases, and networks
 - All organizational data in any form (digital or physical)
 - All business units within Sikaflow
-

4. POLICY OBJECTIVES

This policy aims to:

- Ensure confidentiality, integrity, and availability (CIA) of information assets
- Reduce cybersecurity risks across systems and infrastructure
- Establish consistent security controls across the organization
- Support compliance with security frameworks and best practices
- Enable secure and reliable business operations

5. POLICY STATEMENT

Sikaflow is committed to protecting its information assets through the implementation of appropriate administrative, technical, and physical security controls. All users are required to comply with this policy to ensure secure handling of organizational systems and data.

6. INFORMATION SECURITY CONTROLS

6.1 Logging and Monitoring

- All critical systems must have logging enabled
- Logs must be retained for a minimum of **90 days**
- Logs must be forwarded to a centralized SIEM system
- Logs must be reviewed daily by the IT Security Team
- Suspicious activity must be escalated within 24 hours

6.2 Patch Management

- Critical vulnerabilities must be patched within **7 days**
- High-risk vulnerabilities must be patched within **14 days**
- Medium-risk vulnerabilities must be patched within **30 days**
- Low-risk vulnerabilities must be patched within **90 days** or scheduled maintenance
- Regular vulnerability scans must be conducted

6.3 Encryption Standards

- Data in transit must use **TLS 1.2 or higher**
- Data at rest must be encrypted using **AES-256**
- Encryption keys must be securely stored and access restricted

6.4 System Hardening

- Unnecessary services, ports, and protocols must be disabled
- Default credentials must be changed before deployment
- Secure configuration baselines must be applied
- Administrative privileges must be strictly controlled

6.5 Access Control

- Access must follow the principle of least privilege
- User accounts must be unique and traceable
- Privileged access must be reviewed quarterly
- Access must be revoked immediately upon termination

6.6 Incident Reporting

- All security incidents must be reported immediately
- Incidents must be logged and classified by severity
- Response must follow the Incident Response Procedure

7. ROLES AND RESPONSIBILITIES

- **Management:** Provides governance oversight and approves policies
- **IT Security Team:** Implements and monitors security controls
- **System Administrators:** Maintain system security and patching
- **Employees:** Comply with policies and report incidents

8. POLICY EXCEPTIONS

- Exceptions must be formally documented
- Must include justification and risk assessment
- Must include mitigation controls

- Must be approved by IT Manager and Security Lead
 - Must have an expiry date
-

9. ENFORCEMENT

Non-compliance with this policy may result in:

- Disciplinary action
 - Suspension of system access
 - Termination of employment
 - Legal action where applicable
-

10. REVIEW AND MAINTENANCE

- This policy shall be reviewed annually
 - It must also be reviewed after major system or risk changes
 - The Security Lead is responsible for initiating reviews
-

11. COMPLIANCE AND RISK ALIGNMENT

This policy aligns with:

- ISO/IEC 27001 Information Security Standards
- NIST Cybersecurity Framework (CSF)

It addresses risks including:

- Unauthorized system access
- Database exposure
- SMB and network vulnerabilities
- Insider threats
- Unpatched system exploitation

SIKAFLOW ACCESS CONTROL POLICY

1. POLICY OVERVIEW AND CONTEXT

Access control is a critical component of Sikaflow's cybersecurity framework. As systems and data become increasingly exposed to internal and external threats, strict access management is required to prevent unauthorized access, data breaches, and system misuse.

This policy defines the rules and controls for managing user identities, authentication, authorization, and privileged access within Sikaflow.

2. PURPOSE

The purpose of this policy is to ensure that access to Sikaflow systems, applications, and data is restricted to authorized individuals only, based on business need and security principles.

3. SCOPE

This policy applies to:

- All employees, contractors, and third-party users
 - All IT systems, applications, databases, and networks
 - All cloud services and remote access environments
 - All organization information assets
-

4. POLICY OBJECTIVES

This policy aims to:

- Prevent unauthorized access to systems and data
 - Enforce strong authentication and identity controls
 - Ensure accountability through user traceability
 - Minimize security risks through least privilege access
 - Protect critical systems and sensitive data
-

5. POLICY STATEMENT

Sikaflow enforces strict access control mechanisms based on business requirements, role-based access control (RBAC), and the principle of least privilege. All access must be authorized, monitored, and regularly reviewed.

6. ACCESS CONTROL REQUIREMENTS

6.1 Account Management

- All users must have unique and identifiable accounts
 - Shared accounts are strictly prohibited
 - User accounts must be provisioned based on job role and authorization
 - Inactive accounts must be disabled after 30 days
-

6.2 Role Based Access

Control (RBAC)

- Access must be granted based on defined job roles
 - Users must only access systems required for their duties
 - Role assignments must be reviewed periodically
-

6.3 Least Privilege Principle

- Users must be granted the minimum level of access required
 - Elevated privileges must be justified and time-bound
 - Privilege escalation must be approved and logged
-

6.4 Multi-Factor Authentication

(MFA)

MFA is mandatory for:

- Administrative accounts
 - Remote access systems (VPN, cloud platforms)
 - Financial systems and customer databases
- Approved MFA methods include:
- Authenticator applications (e.g., Microsoft Authenticator, Google Authenticator)
 - Hardware security tokens for privileged users

SMS-based authentication is prohibited for critical systems.

6.5 Privileged Access

Management (PAM)

- Privileged accounts must be strictly controlled and monitored
 - Administrative activities must be logged and reviewed regularly
 - Privileged access must be time-bound where possible □ Use of shared admin accounts is prohibited
-

6.6 Access Reviews

- User access rights must be reviewed every 3 months
 - Access must be revoked immediately upon role change or termination
 - Managers are responsible for validating user access rights
-

6.7 Session Management

- Systems must automatically lock after 10 minutes of inactivity
- Users must re-authenticate after session timeout
- Remote sessions must be securely terminated after use

6.8 Monitoring and Logging

- All authentication attempts must be logged
- Failed login attempts must be monitored and investigated
- Unauthorized access attempts must be escalated immediately
- Security logs must be retained for audit purposes

7. ROLES AND RESPONSIBILITIES

- **IT Security Team:** Manages access control policies and monitoring
- **System Administrators:** Implement technical access controls
- **Managers:** Approve user access requests and validate roles
- **Users:** Protect credentials and comply with access rules

8. POLICY EXCEPTIONS

- All exceptions must be formally documented
- Must include justification and risk assessment
- Must include compensating security controls
- Must be approved by IT Manager and Security Lead
- Must have an expiry date and be periodically reviewed

9. ENFORCEMENT

Non-compliance with this policy may result in:

- Suspension or revocation of access privileges
 - Disciplinary action
 - Termination of employment
 - Legal action where applicable
-

10. REVIEW AND MAINTENANCE

- This policy must be reviewed annually
 - It must also be reviewed after major system or security changes
 - The IT Security Lead is responsible for initiating reviews
-

11. RISK AND COMPLIANCE ALIGNMENT

This policy supports mitigation of risks including:

- Unauthorized system access
- Telnet and legacy protocol exposure
- SMB and network exploitation
- Credential Theft and Privilege Misuse

It aligns with:

- ISO/IEC 27001 Access Control Requirements
- NIST Cybersecurity Framework (CSF)

SIKAFLOW PASSWORD POLICY

1. POLICY OVERVIEW AND CONTEXT

Weak authentication mechanisms are a primary cause of security breaches globally. This policy establishes strong password and authentication standards to protect Sikaflow systems, applications, and sensitive data from unauthorized access and credential-based attacks.

2. PURPOSE

The purpose of this policy is to define secure authentication requirements that ensure only authorized users can access Sikaflow systems and data.

3. SCOPE

This policy applies to:

- All employees, contractors, and third-party users
 - All systems, applications, databases, and network services
 - All organizational accounts including administrative and service accounts
-

4. POLICY OBJECTIVES

This policy aims to:

- Strengthen authentication security across all systems
 - Prevent unauthorized access and credential compromise
 - Enforce secure password creation and management practices
 - Reduce risks from weak or reused passwords
 - Support compliance with security best practices
-

5. POLICY STATEMENT

Sikaflow enforces strong authentication controls to ensure that all user accounts are protected by secure password practices and additional safeguards where applicable.

6. PASSWORD REQUIREMENTS

6.1 Password Complexity

Passwords must meet the following requirements:

- Minimum length:
 - 12 characters (standard users)
 - 16 characters (privileged/admin users)
 - Must include:
 - Uppercase letters (A–Z)
 - Lowercase letters (a–z)
 - Numbers (0–9)
 - Special characters (!@#\$%^&*)
 - Must not include:
 - Username or personal identifiers
 - Company name or system names
-

6.2 Password Reuse Policy

- Password reuse is strictly prohibited
 - Users must not reuse previous passwords
 - Password history must prevent reuse of at least the last 5 passwords
-

6.3 Password Management

- Default passwords must be changed immediately upon first login
 - Privileged accounts must use secure password manager-generated credentials
 - Passwords must not be shared under any circumstances
-

6.4 Account Lockout Policy

- Accounts must lock after **5 consecutive failed login attempts**
 - Locked accounts must be reviewed and reset by IT Security or System Administrators
-

6.5 Password Expiration Policy

Important modern security improvement note:

(Traditional 90-day expiry is now discouraged in modern standards unless compromise is suspected.) So

we upgrade it professionally:

- Passwords do NOT expire on a fixed 90-day cycle
 - Passwords must be changed immediately if:
 - Compromise is suspected
 - Security Incident occurs
 - User role changes or access is elevated
-

6.6 Secure Password Storage

- Passwords must NEVER be stored in plain text
 - Passwords must be hashed using strong algorithms such as:
 - bcrypt
 - Argon2 (preferred)
 - SHA-256 (only when properly salted)
 - Passwords must be salted before hashing
-

6.7 Session Security

- Systems must enforce automatic session timeout after 10–15 minutes of inactivity
 - Users must re-authenticate after session expiration
 - Sensitive systems must require re-authentication for critical actions
-

7. ROLES AND RESPONSIBILITIES

- **Users:** Responsible for creating, protecting, and managing secure passwords
 - **IT Security Team:** Enforces password policy and monitors authentication activity
 - **System Administrators:** Implement technical controls (lockout, hashing, session rules) □
- Management:** Ensures policy enforcement across the organization
-

8. POLICY ENFORCEMENT

Non-compliance may result in:

- Suspension of system access
 - Mandatory security training
 - Disciplinary action
 - Termination of employment in severe cases
-

9. REVIEW AND MAINTENANCE

- This policy must be reviewed annually
 - It must also be updated following security incidents or system changes
 - IT Security Lead is responsible for initiating reviews
-

10. RISK AND COMPLIANCE ALIGNMENT

This policy mitigates risks such as:

- Credential theft and phishing attacks
- Weak authentication exploitation
- Unauthorized system access
- Database compromise due to weak passwords

It aligns with:

- ISO/IEC 27001 Access Control Requirements
- NIST Cybersecurity Framework (CSF)
- Sikaflow Risk Register

SECTION 4: SECURITY METRICS & KPIs

4.1 Purpose

This section defines key performance indicators (KPIs) used to measure the effectiveness of Sikaflow’s cybersecurity program and ensure continuous improvement.

4.2 Key Security Metrics

1. Patch Management

- Percentage of critical vulnerabilities patched within 7 days •
- Target: **≥ 95%**
-

2. Incident Detection and Response

- Mean Time to Detect (MTTD)
- Mean Time to Respond (MTTR)

Targets:

- MTTD: **< 24 hours**
 - MTTR: **< 48 hours**
-

3. Access Control

- Percentage of user access reviews completed quarterly
 - Target: **100%**
 - Number of unauthorized access attempts detected monthly
-

4. Security Awareness

- Percentage of employees completing security awareness training •

Target: **100% annually**

5. System Monitoring

- Percentage of critical systems with logging enabled

Target: **100%**

6. Backup and Recovery

- Backup success rate

Target: **≥ 98%**

- Recovery testing success rate

Target: **100% (tested quarterly)**

4.3 Reporting and Review

- Security metrics must be reviewed:
- **Monthly** by the IT Security Team
- **Quarterly** by Management

Reports must be submitted to:

- Security Lead (CISO)
- Executive Management
- Identified gaps must be addressed through corrective actions.